Overview :-

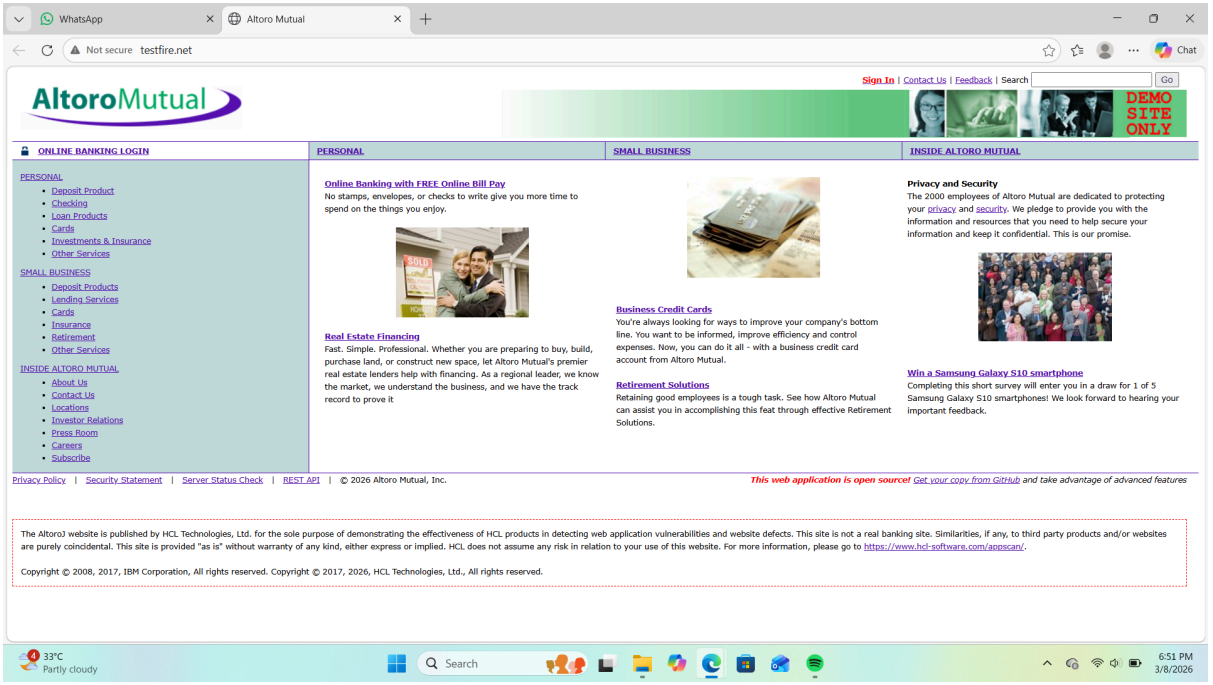
Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to
run scans on a schedule or manually.
Here is a step-by-step explanation of how Nessus works:
1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be
used to prioritise remediation efforts.
Here are some of the benefits of using Nessus:
● Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
● Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
● Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
● Flexibility: Nessus can be configured to run scans on a schedule or manually.
Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable

Target website ➖ :- http://testfire.net/

The site has several known vulnerabilities, including:
- SQL Injection: allowing attackers to bypass authentication and access sensitive data

- Authentication Bypass: enabling unauthorized access to admin accounts
- HTTP Request Smuggling: allowing cache poisoning and session hijacking
- Cross-Site Scripting (XSS): permitting JavaScript injection
- Default Credentials: using weak admin passwords
- No Login Rate Limit: making it vulnerable to brute-force attacks
- Static Session ID: allowing session fixation attacks
- Cleartext Submission of Password: transmitting passwords over HTTP
- Clickjacking: enabling clickjacking attacks

Target ip address:- 65.61.137.117



vulnerability

1 TLS Version 1.0 Protocol

Detection

MEDIUM 104743

2 TLS Version 1.1 Protocol

Deprecated

MEDIUM 157288

3 SSL/TLS Diffie-Hellman Modulus

<= 1024 Bits (Logjam)

LOW 83875

4 ICMP Timestamp Request Remote

Date Disclosure

INFO

10114

5 Additional DNS Hostnames INFO

46180

6 Apache Tomcat Detection INFO

39446

7 Common Platform Enumeration

(CPE)

INFO 45590
8 Device Type INFO 54615
9 HSTS Missing From HTTPS Server INFO 84502
10 HTTP Server Type and Version INFO 10107

severity : -

157288 - TLS Version 1.1 Protocol Deprecated
Severity: - MEDIUM
Plugin: - 157288
Port: - 443
Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks
support for current and recommended cipher suites. Ciphers that support encryption before MAC
computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1

As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer
function properly with major web browsers and major vendors.
Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Plugin:-

Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection

Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a

number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these

problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and

should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer

function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI

terminals (and the SSL/TLS termination points to which they connect) that can be verified as not

being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated

Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks

support for current and recommended cipher suites. Ciphers that support encryption before MAC

computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1

As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer

function properly with major web browsers and major vendors.

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman

moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find

the shared secret in a short amount of time (depending on modulus size and attacker resources).

This may allow an attacker to recover the plaintext or potentially violate the integrity of

connections.

Port :-

Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Description:-

Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE

(Common Platform Enumeration) matches for various hardware and software products found on

a host.

Note that if an official CPE is not available for the product, this plugin computes the best

possible CPE based on the information available from the scan.

Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote

system type is (eg: a printer, router, general-purpose computer, etc).

Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security

(HSTS). HSTS is an optional response header that can be configured on the server to instruct the

browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-

stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS.

solution:-

Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web

server.

Solution: - N/A

Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security

(HSTS). HSTS is an optional response header that can be configured on the server to instruct the

browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-

stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS.

5)Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by

miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host.

Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com [192.0.32.10]

Business Impact::-

Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Business Impact: -This does not pose an immediate threat to business operations or data

security. It indicates the discovery of hostnames that are associated with the remote host,

particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk

on its own, it could be useful for understanding the server's configuration and infrastructure.

Organizations should consider this information as part of their network documentation but do not

need to take immediate action to mitigate it as a security threat.

Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server

Business Impact: -Is an informational finding that identifies the presence of a remote Apache

Tomcat web server. While this information itself does not indicate a security threat or impact on

business operations, it can be useful for network administrators and security professionals to be

aware of the technologies in use on their network. Understanding the presence of an Apache

Tomcat server can be valuable for maintaining and securing web applications, but it does not

require immediate action to mitigate a security risk.

8)Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote

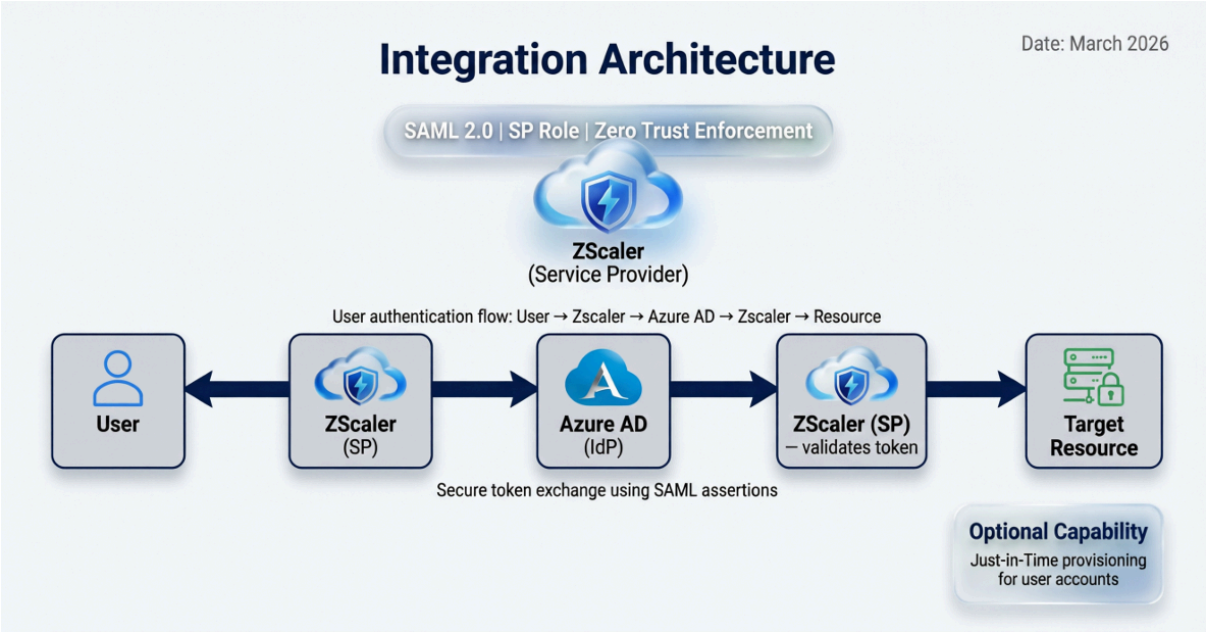
system type is (eg: a printer, router, general-purpose computer, etc).

Business Impact: - It allows for the identification of the remote system type, such as a printer,

router, or general-purpose computer, based on the remote operating system. While this doesn't

pose a direct security threat, it offers valuable insights for network administrators to better

understand and classify the devices in their network. This information aids in network



Conclusion

✅ *Conclusion:* (link unavailable) is a deliberately vulnerable web application designed for security testing

and training, offering a safe environment to practice identifying and exploiting common web vulnerabilities like SQL injection, XSS, and authentication bypass.

Summary and Next Steps

Date: March 2026

Key Summary Points

- "Integration of Zscazer with Azure AD enables secure, seamless access"
- "Leverages existing identity infrastructure for Zero Trust enforcement"
- "Key success factors: proper configuration, testing, and ongoing management"
- Recommended next steps: expand to additional IdPs, enable advanced policies, schedule regular reviews"

Strategic Roadmap Ahead

- "Expand IdP ecosystem: integrate Okta, Ping Identity, and custom SAML providers"
- Enable advanced Zero Trust policies: device posture checks, adaptive risk scoring, session timeout controls"
- Institutionalize governance: quarterly review cycles, audit log retention, and policy versioning"

From integration to institutionalization — building resilient, scalable, and auditable Zero Trust access.